Enumerate Infrastructure and Application Admin Interface

AIM:

To famialiarize tools for enumerating Infrastructure and Application Admin Interface.

Description:

Administrator interfaces may be present in the application or on the application server to allow certain users to perform privileged activities on the site. Tests should be undertaken to reveal if and how this privileged functionality can be accessed by an unauthorized or standard user.

An application may require an administrator interface to enable a privileged user to access functionality that may make changes to how the site functions. Such changes may include:

•user account provisioning

•site design and layout

•data manipulation

•configuration changes

In many instances, such interfaces do not have sufficient controls to protect them from unauthorized access. Testing is aimed at discovering these administrator interfaces and accessing functionality intended for the privileged users.

There are a wide variety of administration interfaces for different technologies. For example:

•Remote management protocols such as SSH, PowerShell, RDP and VNC

•Browser-based management such as cloud-based web consoles and appliance configuration panels

•APIs that expose management functionality

•Thick clients - typically, software installed on a device that drives an administration protocol or API in the background

Some systems are managed through code and configuration files rather than the interfaces listed above. This can also be a form of system administration.

Administration interfaces are an attack surface. Only legitimate administrators should be able to communicate with them. You should isolate these interfaces using architectural controls and

constrain who can connect to the system and from where. This will help to protect against attacks such as brute forcing administrator login, or using an exploit to gain access.

There are a number of ways that you can reduce the exposure of your management interfaces. For example:

- ✓ You could create a dedicated management network that only authorised administrators have physical access to.
- ✓ You could place your administration interfaces behind a VPN that only authenticated administrators and devices can use.
- ✓ You could implement an IP allow list to restrict the devices or networks that can access the administration interface.

Some architectural controls are stronger than others. For example, IP allow lists can be overcome if the attacker is able to share the IP address space, or spoof it. They can also be difficult to maintain.

Depending on your risk appetite, it may be necessary to combine multiple mitigations to adequately protect your administration interfaces.The mitigations that you choose will depend on a number of factors, including where the interface is located, what it allows access to and who the administrators are that need access to it.

Implementation guidance

- ✓ Only permit authorised devices. It should not be possible for untrusted devices to access your administration interfaces. Architectural controls should be implemented to ensure that the origin of administration activities is a trusted device. This helps to reduce the attack surface.
- ✓ Use browse down, not browse up. If an attacker compromises a less trusted device, they will inherit it's accesses. If that device can be used to browse up to a more critical system, the attacker can do so too. See 1 - Gain trust in your management devices for more information.
- ✓ Authenticate the administrator. Administrators must be authenticated before carrying out their duties. Authentication should be achieved using well known protocols.
- ✓ Utilise multi-factor authentication. Where available, MFA should be enabled on administrator accounts. This introduces a high hurdle for an attacker to jump, but has little effect on administrators. Remember that this isn't bulletproof: if an adversary has

access to the PAW, they can piggyback on an authenticated session after MFA has been completed.

- ✓ Protect your administration credentials. Discourage administrators from writing credentials on post-it notes and consider the use of a password manager. Also ensure that credentials are not hard-coded into software projects, as they could mistakenly be published to a code repository. If certificates are used for authentication, carefully protect them. See our password guidance for more information.
- ✓ Use Privilege Access Management. See 4 - Use privileged access management for more information.
- ✓ Use secure protocols. The protocol that is used to carry traffic from a Privileged Access Workstation to the administration interface should be encrypted. If it is not, an attacker could view the traffic and manipulate it. For example, APIs using HTTPS should be preferred over Telnet. You should investigate what protocol is used by any thick client and ensure that these connections are protected too.
- ✓ Update your administration infrastructure. Updates should be installed to ensure that your systems are patched against known vulnerabilities. These updates should be installed as soon as possible, because attackers put effort into understanding them, searching for the vulnerabilities that they patch.
- ✓ Monitor administration activities. See 5 - Log and audit administration activities for more information.
- ✓ Implement procedural policies governing system administrators. System administration policies should cover a wide number of topics. For example, the number of administrators should be bounded with upper and lower limits that are appropriate to your environment. Further, the principal of least privilege should be applied, and a robust 'joiners, movers and leavers' process should be defined.

Procedure:

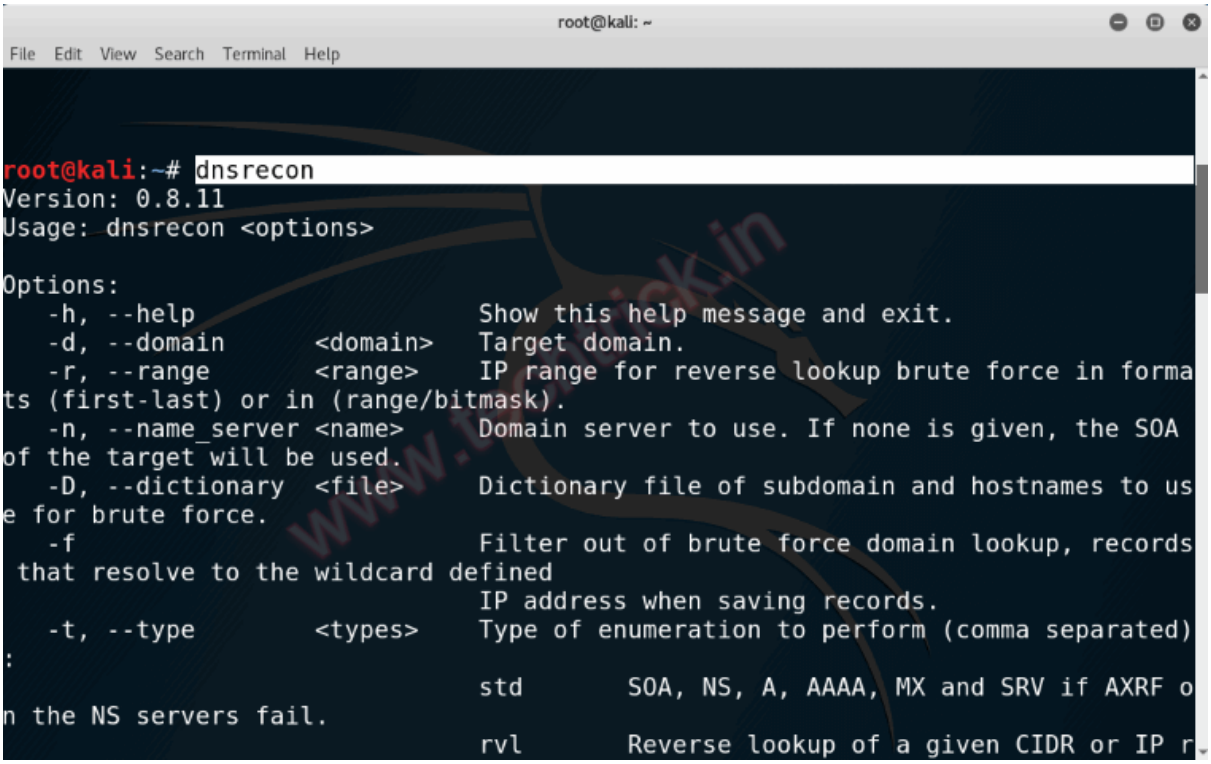
- ✓ ***Dnsrecon***

  DNSRecon is a Python script that provides the ability to perform:

  - Check all NS Records for Zone Transfers.
  - Enumerate General DNS Records for a given Domain (MX, SOA, NS, A, AAAA, SPF and TXT).
  - Perform common SRV Record Enumeration.

- Top Level Domain (TLD) Expansion.
- Check for Wildcard Resolution.
- Brute Force subdomain and host A and AAAA records given a domain and a wordlist.
- Perform a PTR Record lookup for a given IP Range or CIDR.
- Check a DNS Server Cached records for A, AAAA and CNAME
- Records provided a list of host records in a text file to check.
- Enumerate Hosts and Subdomains using Google

type DnsRecon on the kali linux terminal.



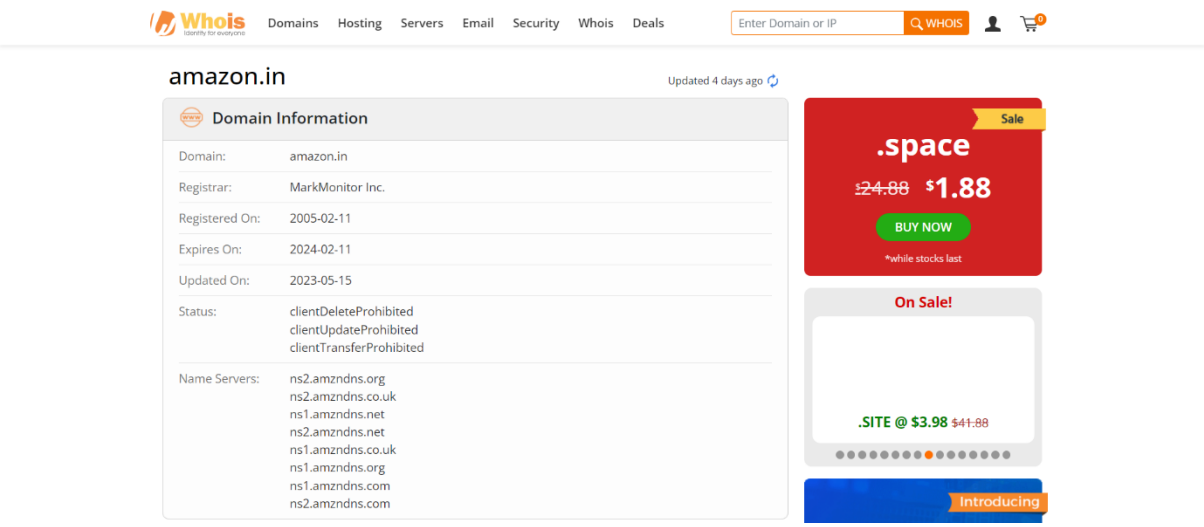
✓ ***theHarvester***

theHarvester is a command-line tool included in Kali Linux that acts as a wrapper for a variety of search engines and is used to find email accounts, subdomain names, virtual hosts, open ports / banners, and employee names related to a domain from different public sources (such as search engines and PGP key servers). In recent versions, the authors added the capability of doing DNS brute force, reverse IP resolution, and **Top-Level Domain** (**TLD**) expansion.

✓ In the following example, theHarvester is used to gather information about zonetransfer.me:



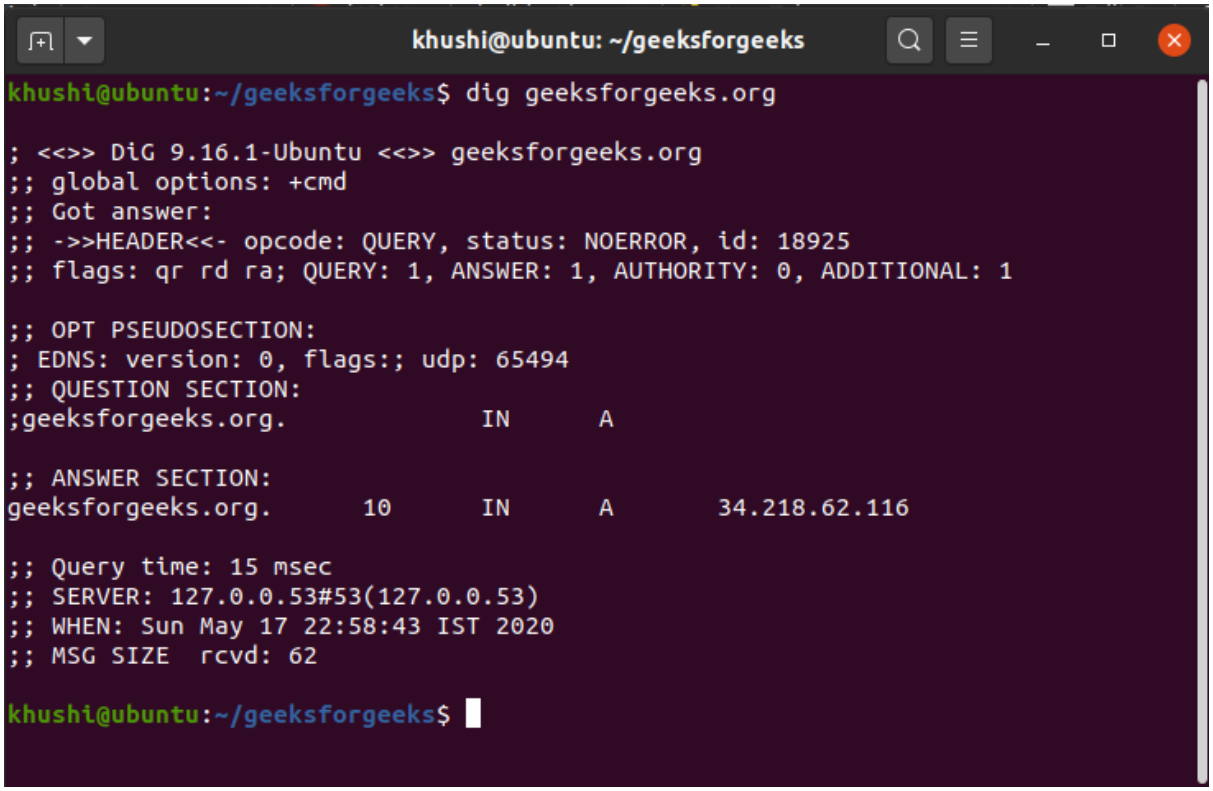
- ✓ ***Finding subdomain info***



✓ ***Dig***

dig command stands for Domain Information Groper. It is used for retrieving information about DNS name servers. It is basically used by network administrators. It is used for verifying and troubleshooting DNS problems and to perform DNS lookups. Dig command replaces older tools such as nslookup and the host.

dig geeksforgeeks.org



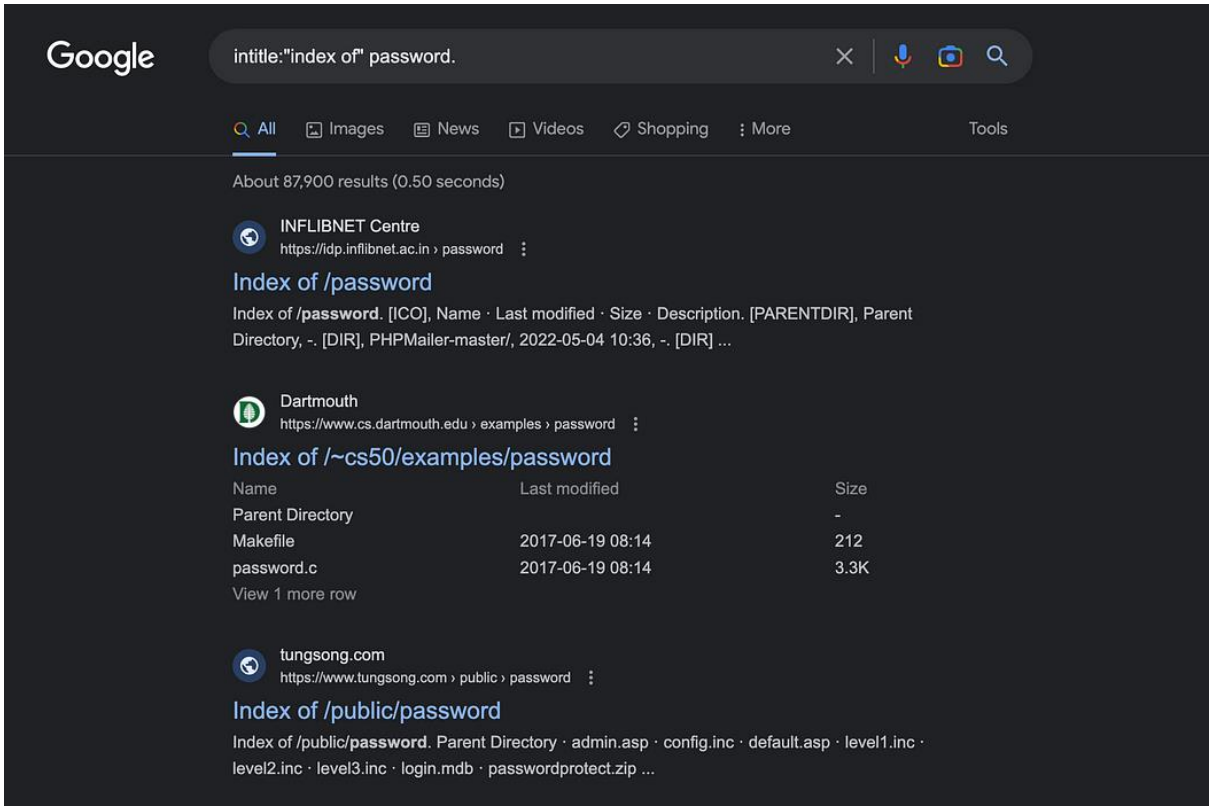
✓ **Google Dorking**

A Google Dork is a special search term. These terms, when used with regular search keywords, can help us discover hidden resources crawled by Google.

Here are some of the most common operators used in Google Dorking.

Intitle operator

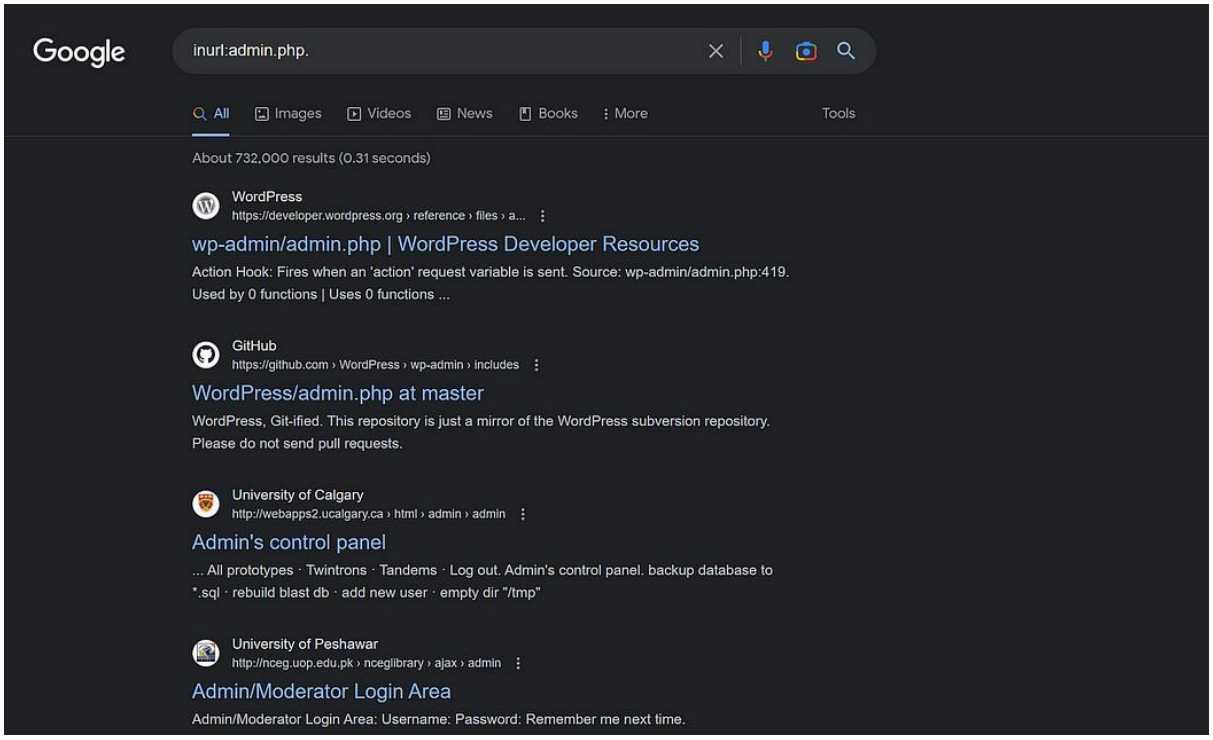
The "**intitle**" operator searches for web pages with specific words or phrases in the title tag. For instance, if you're looking for pages that contain the phrase "password" and have "index of" in the title, you would use the search term:intitle:"index of" password.



In title. Image by the author.

Inurl operator

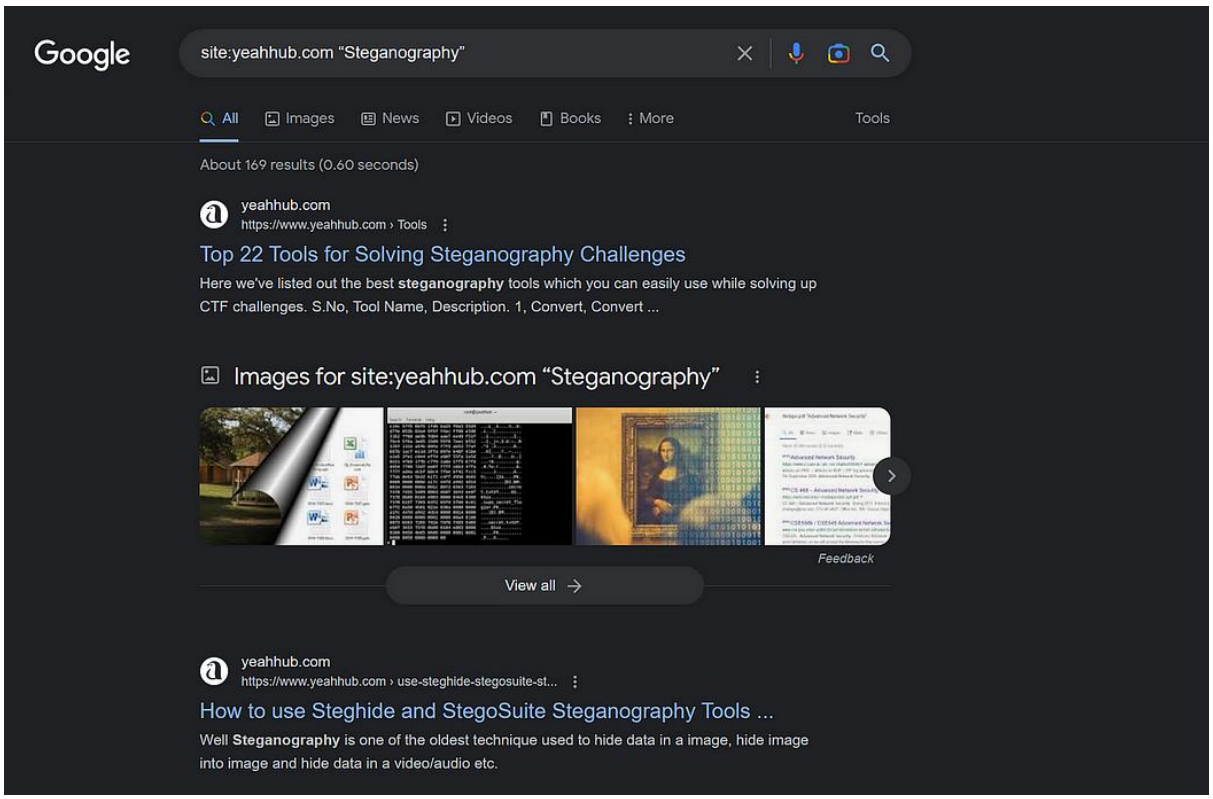
The "**inurl**" operator searches for web pages that contain specific words or phrases in the URL. For example, if you're looking for pages that contain "admin.php" in the URL, you would use the search term:inurl:admin.php.



In url. Image by the author.

Site operator

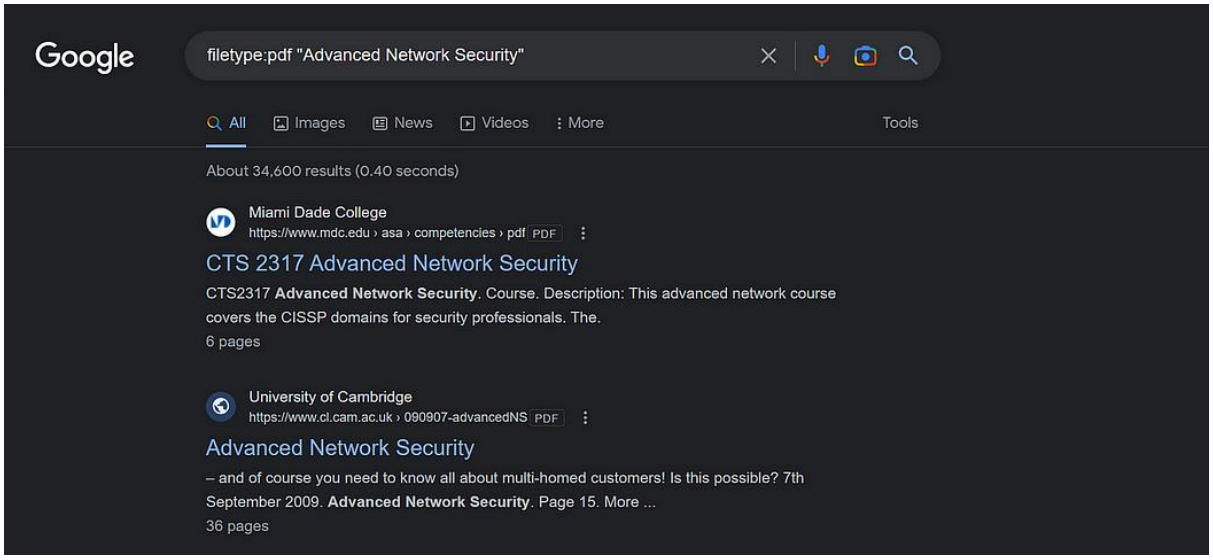
The “**site**” operator allows you to search within a specific website or domain. For instance, if you’re looking for pages on the example.com domain that contain the word “Steganography”, you would use the search term:site:yeahhub.com “Steganography”



In site. Image by the author.

Filetype operator

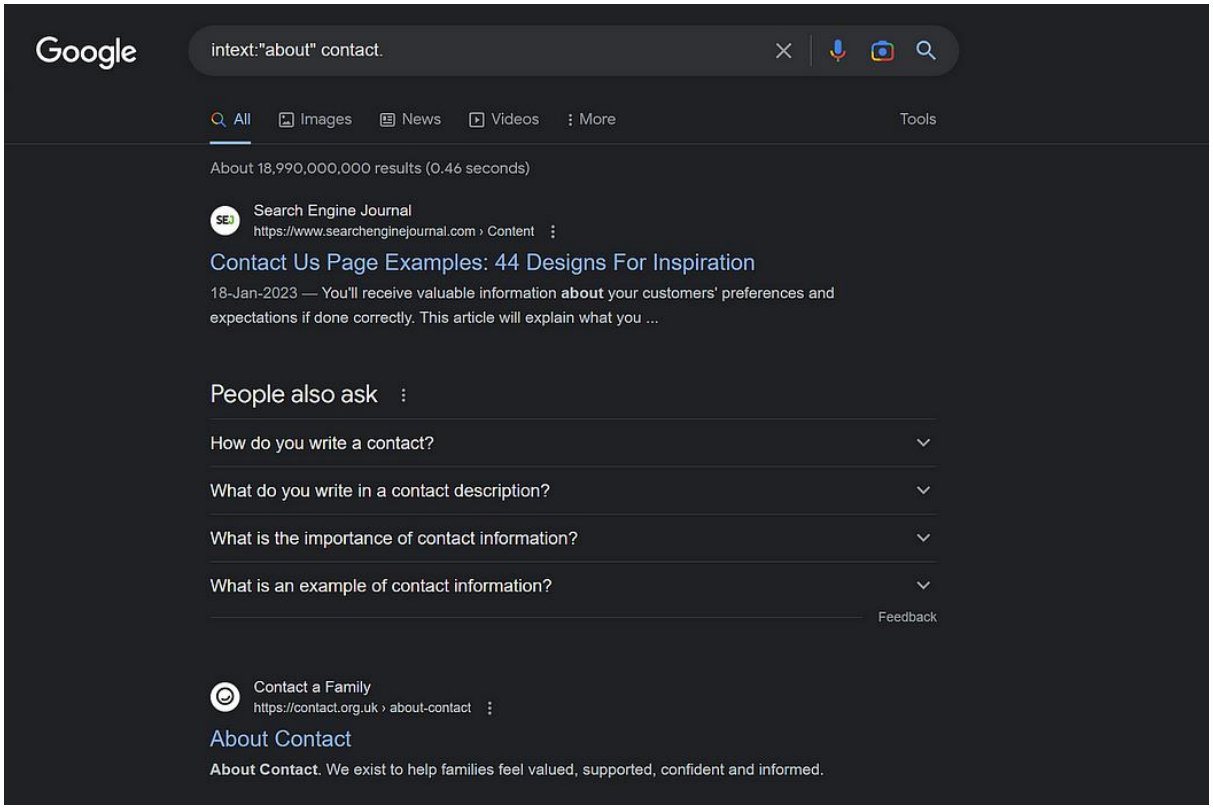
The “**filetype**” operator allows you to search for specific file types, such as PDFs or Word documents. For example, if you’re looking for PDF files that contain the phrase “confidential report”, you would use the search term:filetype:pdf "Advanced Network Security"



Filetype. Image by the author.

Intext operator

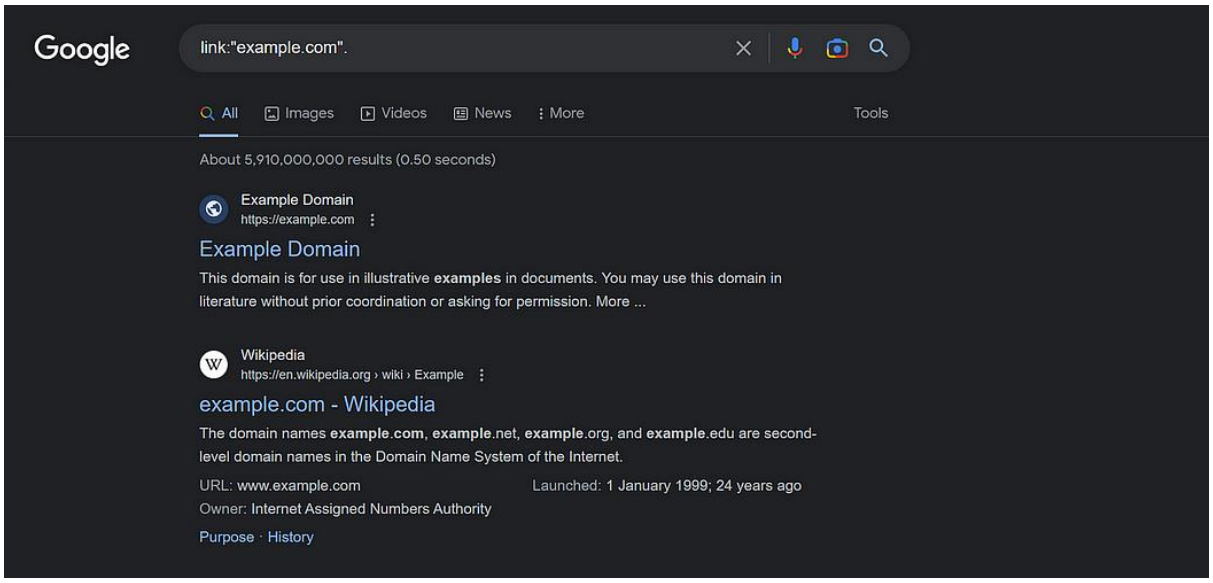
The “**intext**” operator searches for pages that contain specific words or phrases within the body of the page. For instance, if you’re looking for pages that contain both the words “login” and “password” within the body of the page, you would use the search term:intext:"about" contact.



In text. Image by the author.

Link operator

The "**link**" operator searches for web pages that link to a specific URL. For example, if you're looking for web pages that link to the example.com domain, you would use the search term:link:"example.com"

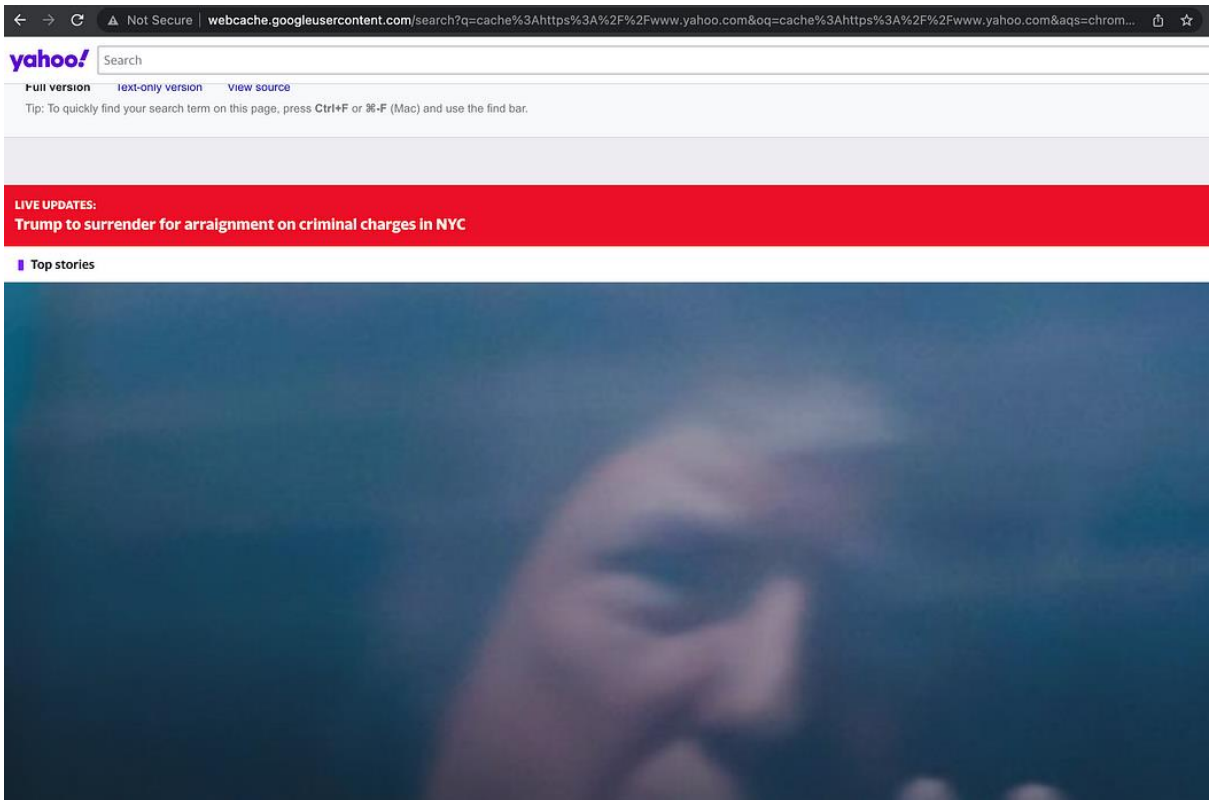


Link operator. Image by the author.

Cache operator

The "**cache**" operator is used to retrieve the cached version of a web page. When you search for a website using Google, Google creates a cached version of that page in its system. This version can be useful if the original website is temporarily down or if you want to view an older version of the website.

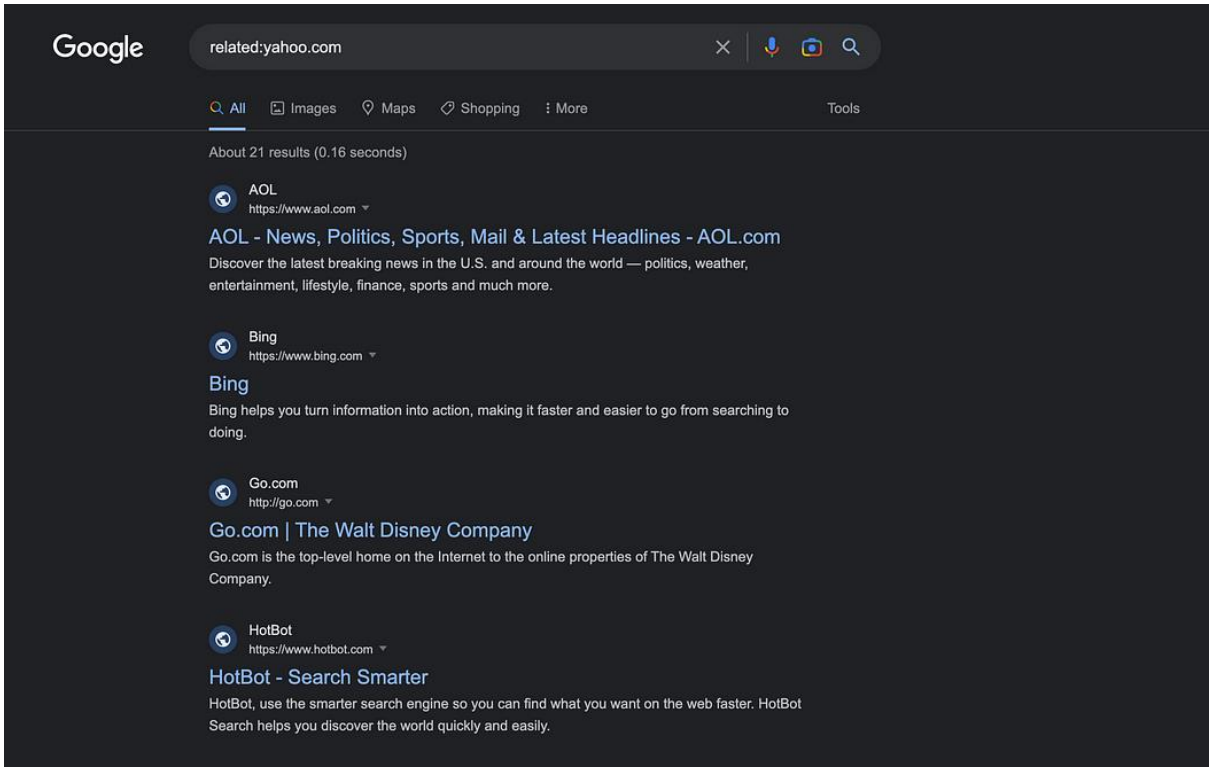
Here is the syntax to find the cached version of yahoo.com.cache:https://www.yahoo.com



Cached version of yahoo.com. Image by author.

Related operator

The "**related**" operator is used to find web pages that are related to a specific URL. Here is the syntax to use the "related" operator to find sites similar to yahoo.com.



Related operator. Image by author.

By combining these operators in creative ways, you can find specific types of information on the web that can be useful for penetration testing and other purposes.